Your ten-minute test drive

Three short scenarios, each from a different seat: the roadside, the consulting room, and the patient's own phone. All people and records are fictional demonstration data, so press every button you like.

App	Address	Best on
Patient app	https://13-247-143-188.sslip.io/patient/	a phone
Staff portal	https://13-247-143-188.sslip.io/doctor/	a laptop or a phone

Demo accounts

Role	Login ID	Password	Who
Doctor	`naledi.mahlaba`	`compass-lichen-valley-fox-sandstone-89`	Dr Naledi Mahlaba, Emergency Medicine
Doctor	`riaan.botha`	`moss-summit-robin-salt-dahlia-46`	Dr Riaan Botha, Internal Medicine
Nurse	`busisiwe.zulu`	`timber-yarrow-cobalt-comet-thunder-30`	Sister Busisiwe Zulu
Pharmacist	`fatima.ebrahim`	`flint-delta-yellowwood-turtle-hibiscus-14`	Fatima Ebrahim
Lab technician	`kagiso.mokoena`	`dune-papaya-harbour-tide-poplar-72`	Kagiso Mokoena
Paramedic	`bongani.mthembu`	`aurora-lava-delta-fern-moss-10`	Bongani Mthembu
Patient	`thabo.mahlangu`	`desert-nectar-pine-cactus-horizon-31`	Thabo Mahlangu: type 2 diabetes, hypertension, aspirin allergy
Patient	`zanele.khumalo`	`ivory-tortoise-ebony-thistle-galaxy-57`	Zanele Khumalo: asthma, folic acid
Patient	`johan.pretorius`	`lichen-kestrel-lotus-comet-nectar-14`	Johan Pretorius: atrial fibrillation on warfarin, penicillin allergy
Patient	`ayanda.ngcobo`	`fern-lagoon-turtle-pepper-tide-45`	Ayanda Ngcobo: epilepsy, latex allergy

Two people at once: one browser holds one account. Use a phone for the patient and a laptop for staff, or a normal window and a private (incognito) window.

Scenario A: the roadside (5 minutes)

Thabo collapses at a taxi rank. Bongani, a paramedic, reaches him first.

1. **Thabo, on a phone:** sign in, open **Medical ID** and keep the QR code on screen (or download it).
2. **Bongani, on a laptop:** sign in at the staff portal, open **Emergency access**, choose the approved device, then **QR Code** and **Scan QR code with camera**. Allow the camera and point it at Thabo's screen.
3. Within seconds Bongani sees blood type B+, the aspirin allergy, metformin and amlodipine, and who to call. The access lasts 15 minutes and covers Thabo only.
4. **Thabo:** open **Access history**. Bongani's emergency read is listed, with the time and the reason.

No camera? Choose **Manual** and type Thabo's card number, `DEMO-ZA-0001`.

Scenario B: the consulting room (5 minutes)

Dr Mahlaba sees Thabo for his diabetes review.

1. **Dr Mahlaba: My Patients**, then Thabo. The chart shows allergies, medicines and conditions.
2. Open **Note templates**, choose **Use template**, then **Start a SOAP note with this**: the note opens pre-filled. Choose Thabo and save it.
3. **Messages**, then **Start a new conversation**, choose Thabo and write to him. If Thabo is signed in, the message arrives on his phone without a refresh.
4. Optional: as **Fatima Ebrahim** (pharmacist) or **Kagiso Mokoena** (lab technician), see the same patient from the pharmacy and laboratory side.

Scenario C: the patient in control (3 minutes)

1. **Thabo:** open **Access Control**. Each clinician who can open his record is listed with an expiry date; withdraw one and approve it again.
2. In **Access Control**, open **Forms** to sign or refuse a consent form. A refusal is recorded as a refusal, never as silence.
3. Open **Medications** and **Notifications**: reminders arrive on South African time.

If something does not work, e-mail **kkgawatlh9@gmail.com**. The site is monitored, with alerts on errors and failed sign-ins. Too many wrong passwords lock an account for a short time; that is a security control, not a fault.

The emergency summary that travels with the patient

MediChain gives every patient a health ID they carry as a QR code or NFC card. A responder reads the essentials in seconds; the care team works from one record; and the patient sees every access to it.

Why now

Missing records delay care: in a survey of 40 Limpopo hospitals, patients waited longer and some were "treated without medical history" [1]. Courts have found that "numerous South African public health facilities fail to meet their record-keeping obligations" [2]. The national digital-health strategy asks for a person-centred record and a common patient identifier [3].

What is different

- **Seconds, not phone calls:** QR, NFC or card number, on an approved device.
- **Visible to the patient:** every read, emergency included, in their access history.
- **Provable:** access records are signed and stored write-once.
- **Patient-held consent:** access is granted and withdrawn by the patient.

Traction

Live
on AWS in Cape Town since October 2026

7
roles on one record, 116 screens

1,045
server tests, all passing

2nd
place, Rust Africa Hackathon 2026

Business

A per-facility subscription for private clinics, hospital groups and EMS operators; free for patients. One server in Cape Town runs the whole product today for under USD 60 a month.

The ask

One clinic, hospital or EMS partner for a supervised pilot of the emergency summary and handover, and introductions to health-technology funders.

Lukau Invasion (Pty) Ltd · 2026/600804/07 · Keorapetswe Kgoatlha, founder-developer · kkgawatlh9@gmail.com

Sources

1. Marutha, N. S. & Ngoepe, M. (2017). The role of medical records in the provision of public healthcare services in the Limpopo province of South Africa. *South African Journal of Information Management*, 19(1), a873. https://doi.org/10.4102/sajim.v19i1.873
2. Kolawole, O. (2024). Non-compliant health record-keeping in South Africa: Judicial responses, and progress towards a digital remedy. *The African Journal of Information and Communication*, (33), 1–19. https://doi.org/10.23962/ajic.i33.18892
3. National Department of Health (2019). *National Digital Health Strategy for South Africa 2019–2024*. https://knowledgehub.health.gov.za/system/files/elibdownloads/2023-04/national-digital-strategy-for-south-africa-2019-2024-b.pdf

One evening, two endings

A fictional but ordinary case: Thabo, 55, has type 2 diabetes and high blood pressure and is allergic to aspirin. At 18:40 he collapses at a taxi rank in Tembisa.

Time	Today, with paper folders	With MediChain
18:52 ambulance arrives	Thabo cannot speak. No one on scene knows his conditions, medicines or allergies.	The paramedic scans the QR on Thabo's phone lock screen, or taps his card: blood type, allergies, medicines and next of kin appear.
18:58 treatment starts	Standard chest-pain protocols often include aspirin, so a responder must stop and ask. Nobody can answer.	The aspirin allergy is the first thing on screen. The grant lasts 15 minutes and covers Thabo only.
19:30 hospital handover	His folder is at his clinic, 20 km away. Staff phone family members.	The receiving doctor opens the same record: notes, recent results and current medicines.
Next morning	Thabo has no way to know who read his information.	Thabo's access history lists the paramedic and the doctor, with times and reasons.

This is an illustrative scenario, not a measured outcome. MediChain makes no claim about mortality or error rates; those will be measured in a pilot.

The evidence behind the problem

- **Limpopo, 40 public hospitals:** missing records "negatively affected timely and effective healthcare service delivery"; staff were "unable to assist patients or treat them immediately" [1].
- **National case law, 2024:** poor record-keeping undermines patients' own claims, because facilities fail their legal obligations [2].
- **Khayelitsha Hospital emergency centre:** months of folders stayed un-scanned and unavailable electronically [3] (one hospital, 2012–2013).
- **Policy:** the National Digital Health Strategy calls for a complete electronic record and a common identifier [4].

Who gains what

Who	Before	After
Patients	History scattered across folders; no view of who reads it	Carry their own summary; approve and withdraw access; read their notes, results and messages
Paramedics	Treat blind or wait for a phone call	Allergies and medicines on scene, on an approved device
Doctors and nurses	Re-take histories; handovers on paper	One shared record; notifications only about their own patients
Pharmacists and laboratories	Prescriptions and requests that cannot be traced	Prescriptions and specimens tied to the patient and the prescriber
Facilities	Disputes argued from missing paper	A signed, write-once record of every access

Built for South African reality

- **Load-shedding and weak signal:** the QR carries a printed summary that still shows offline, marked unverified.
- **Any phone:** web apps that install from the browser, with no app-store download or data-heavy update.
- **Local hosting:** data stays in South Africa (AWS Cape Town).
- **Six languages prepared:** English, isiZulu, Kiswahili, Hausa, Amharic and French interface bundles exist; English is complete.

How a pilot will prove it

Measure	How
Seconds to critical information	From first contact to allergies on screen, against the current route
Handover completeness	Share of handovers with allergies, medicines and contacts recorded
Patient understanding	Can patients say who opened their record, and why?
Adoption	Active staff per shift; workflows finished without paper

Sources

1. Marutha, N. S. & Ngoepe, M. (2017). The role of medical records in the provision of public healthcare services in the Limpopo province of South Africa. *South African Journal of Information Management*, 19(1), a873. https://doi.org/10.4102/sajim.v19i1.873
2. Kolawole, O. (2024). Non-compliant health record-keeping in South Africa: Judicial responses, and progress towards a digital remedy. *The African Journal of Information and Communication*, (33), 1–19. https://doi.org/10.23962/ajic.i33.18892
3. Ohuabunwa, E. U., Sun, J., Jubanyik, K. J. & Wallis, L. A. (2016). Electronic medical records in low to middle income countries: the case of Khayelitsha Hospital, South Africa. *African Journal of Emergency Medicine*, 6(1), 38–43. https://doi.org/10.1016/j.afjem.2015.06.003
4. National Department of Health (2019). *National Digital Health Strategy for South Africa 2019–2024*. https://knowledgehub.health.gov.za/system/files/elibdownloads/2023-04/national-digital-strategy-for-south-africa-2019-2024-b.pdf

POPIA by design

Health information is special personal information under the Protection of Personal Information Act 4 of 2013. This document maps MediChain to the Act's eight conditions for lawful processing, shows how an access decision is made, and lists the threats it is built to resist.

The eight conditions, condition by condition

POPIA condition	How MediChain meets it
1. Accountability	Every read and change is attributed to an authenticated account; the audit stream is signed and kept write-once.
2. Processing limitation	Consent is recorded as given or refused with its legal basis; staff open a record only through a grant, a care relationship or a logged emergency.
3. Purpose specification	Each access carries a reason (treatment, emergency, and so on) that the patient can read.
4. Further processing limitation	No analytics, advertising or model training on patient data. Clinical scores are explicit rules run for that patient's care.
5. Information quality	Patients can see their own record. An unmeasured value is shown as unknown, never as zero, and forms send only what was entered.
6. Openness	Access history and consent records are visible to the patient in the app.
7. Security safeguards	Encryption in transit and at rest, step-up authentication, rate limits, alarms, backups with restore tests (below).
8. Data subject participation	Patients approve and withdraw access, sign or refuse consent, and read their notes, results, prescriptions and messages.

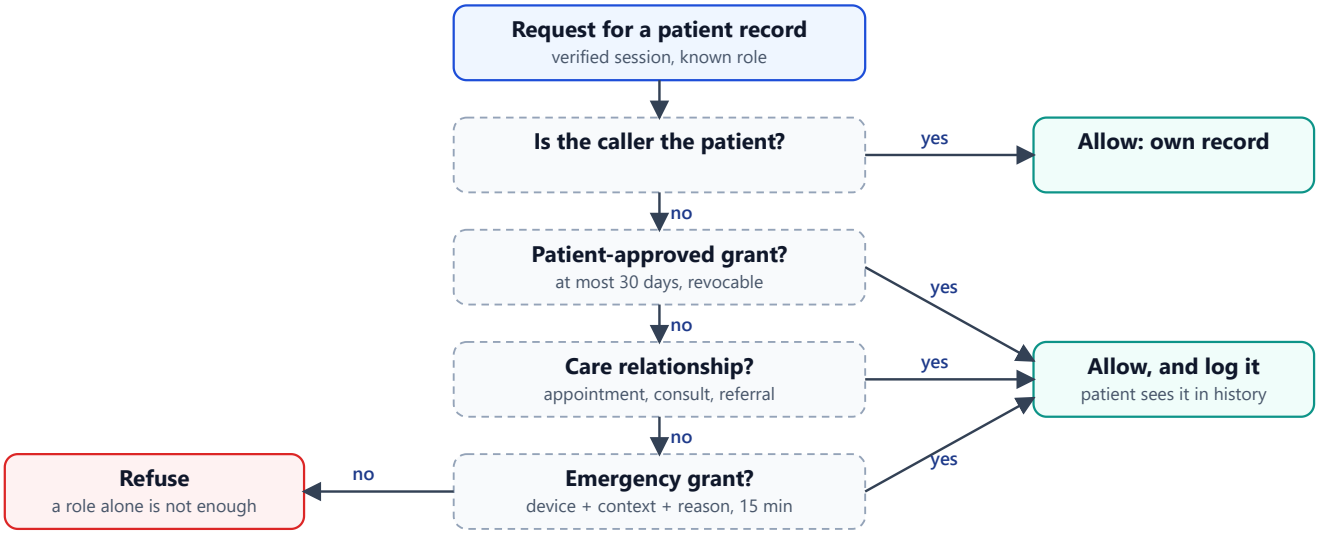


Figure 6. How the server decides whether to open a record. Administrators manage accounts and devices, never clinical records.

Threats and controls

Threat	Control
Stolen password database	The password never leaves the browser: it is stretched with PBKDF2-SHA512 (210,000 rounds) and HKDF into a proof, and the server stores Argon2id over the proof.
Password guessing	60 requests per minute for anonymous callers; account lockout after repeated failures; a CloudWatch alarm on sign-in failures and locks.
Weak or breached passwords	15 characters minimum; checked against breach lists by k-anonymity, so the password itself is never sent.
Curious staff member	A role alone opens nothing. The care relationship or grant is checked on every request, and the patient sees each read.
Misused emergency access	Only on an enrolled device, inside a work context and with a reason; it lasts 15 minutes for one patient and is flagged in the patient's history.
Forged emergency QR	The QR carries a server-signed (HMAC) proof; a typed patient number alone cannot open emergency access.
Insider rewriting the log	Each batch is fingerprinted and Ed25519-signed, then exported to S3 Object Lock, which even the account owner cannot overwrite.
Replayed or doubled writes	Every authenticated change carries an idempotency key; a replay returns the first result and changes nothing.
Cross-site attacks	A strict content security policy, HSTS, own-origin CORS, and no third-party scripts.
Privileged misuse	An authenticator-app (TOTP) step-up for role changes, guardianship and other privileged actions; administrators cannot read clinical records.
Data loss	Nightly encrypted backups to a second store, continuous WAL archiving, and an automatic restore test.

What is stored where

Data	Where	Protection
Clinical records, documents	PostgreSQL in Cape Town	Documents encrypted with ChaCha20-Poly1305; encrypted disk
Emergency summary	Encrypted emergency capsule	Only a commitment (a hash) and a version number enter the audit stream
Audit checkpoints	S3 Object Lock	Ids, digests and timestamps only, never health data
Secrets	AWS Secrets Manager	Never in source code or images

Honest status

Fictional data only until three gates close: a registered Information Officer, POPIA prior authorisation (section 57), and a health-privacy lawyer's sign-off. Records are retired, never destroyed, until retention rules are approved.

MediChain technical architecture

How the system is built, deployed, secured and verified. Version as deployed on 13-247-143-188.sslip.io, October 2026.

Item	Value
Server	Rust 2021, Actix-web 4, Tokio; about 158,000 lines including tests
Clients	React 18 + TypeScript + Vite + Tailwind + Zustand: a staff portal, a patient app and a shared library (about 119,000 lines)
Database	PostgreSQL 16, 165 tables from one schema baseline; sqlx with bound parameters only
Interface	500+ REST endpoints under /api, plus server-sent events at /api/events
Cryptography crate	ChaCha20-Poly1305, Argon2id, Ed25519, zeroisation of key material
Hosting	AWS af-south-1, defined in CloudFormation (40 resources) and deployed by one script

1. System context

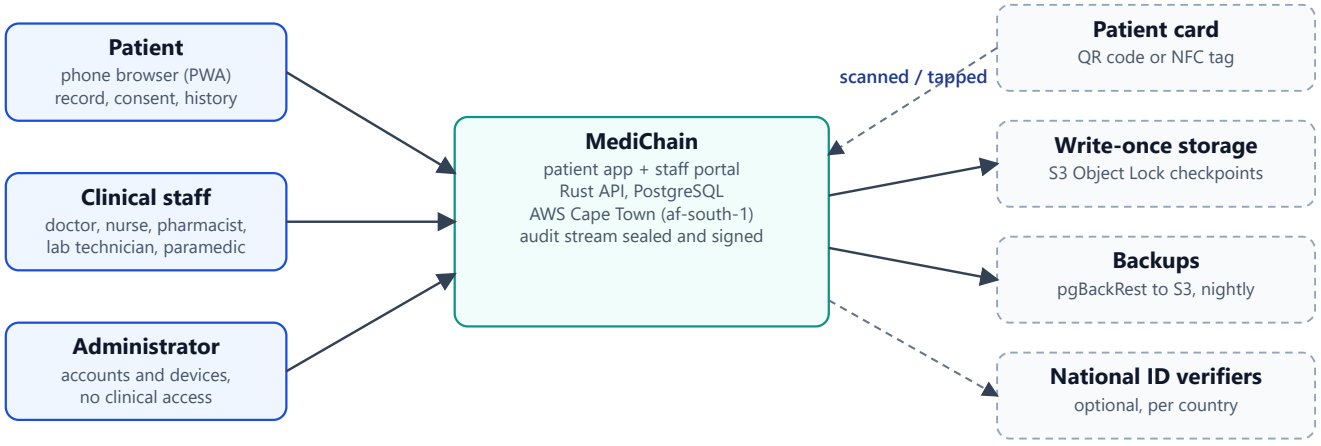


Figure 1. System context: who uses MediChain and what it depends on.

There are two installable web apps (PWAs). The **patient app** is phone-first: record, emergency card, Medical ID QR, access control, consent, medicines, messages. The **staff portal** serves six roles from one codebase; the navigation and every API call are filtered by role. Both talk to the same API and receive live updates over server-sent events.

2. Deployment

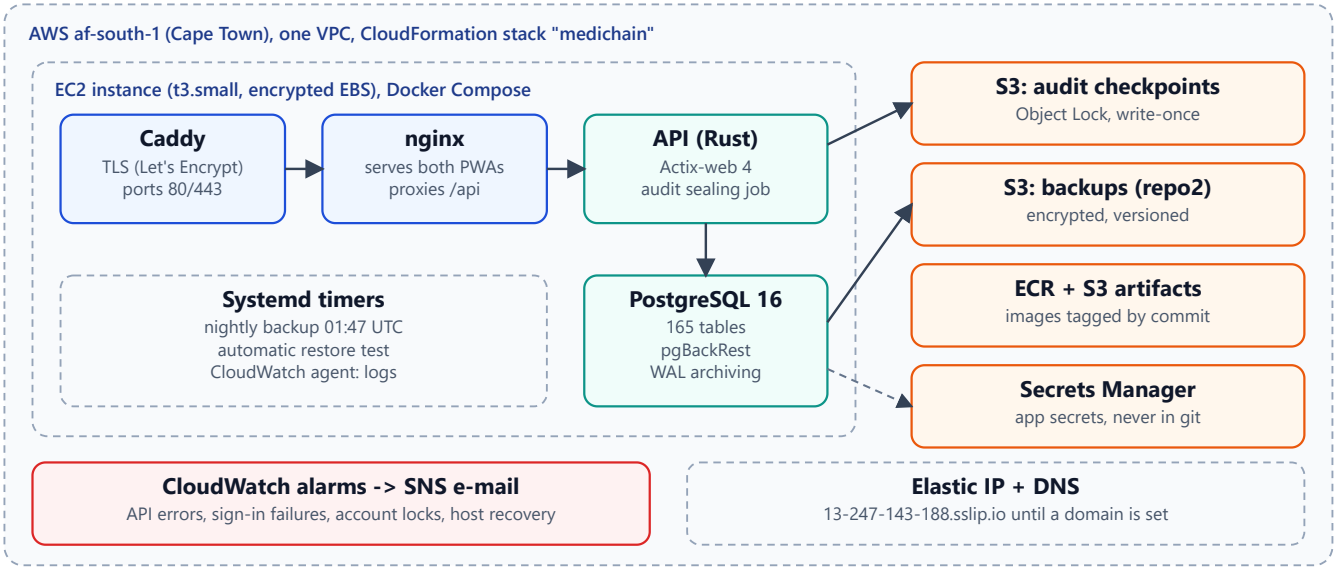


Figure 2. Deployment: everything runs in South Africa; data at rest is encrypted.

A deploy runs five steps: (1) create or update the CloudFormation stack, (2) add any missing application secret on the instance without rotating existing ones, (3) build the API, web and PostgreSQL images and push them to ECR tagged with the git commit, (4) upload the compose bundle to S3, (5) start it on the instance through SSM Run Command. The only inbound ports are 80 and 443; there is no SSH. The instance image is pinned, so a redeploy never replaces the server or its disk.

3. Request lifecycle



Figure 3. Every request passes the same nine checks before its handler runs; the handler then applies role and care-relationship rules.

Inside the handler, the caller comes only from the verified JWT and its durable session; a caller-supplied identity header carries no authority. The handler then checks the role and the relationship to the patient. A handler takes a *request* type, never a domain type, so a form that collects part of a record can still save.

4. Identity and sign-in

1. The browser derives a proof from the password: PBKDF2-SHA512, 210,000 rounds, salted with the login ID, then HKDF-SHA256. The password itself is never sent.
2. The server compares the proof with an Argon2id verifier and issues a JWT bound to a durable, revocable session row.
3. Privileged actions require a fresh authenticator-app (TOTP) code; repeated failures lock the account and raise an alarm.

5. Authorisation and emergency access

Roles rank as Admin, then Doctor and Nurse, then Lab Technician and Pharmacist, then Patient, but a role is necessary rather than sufficient. A record opens only through one of four routes: the patient themself, a patient-approved grant (at most 30 days), a care relationship (appointment, consultation or referral), or an emergency grant.

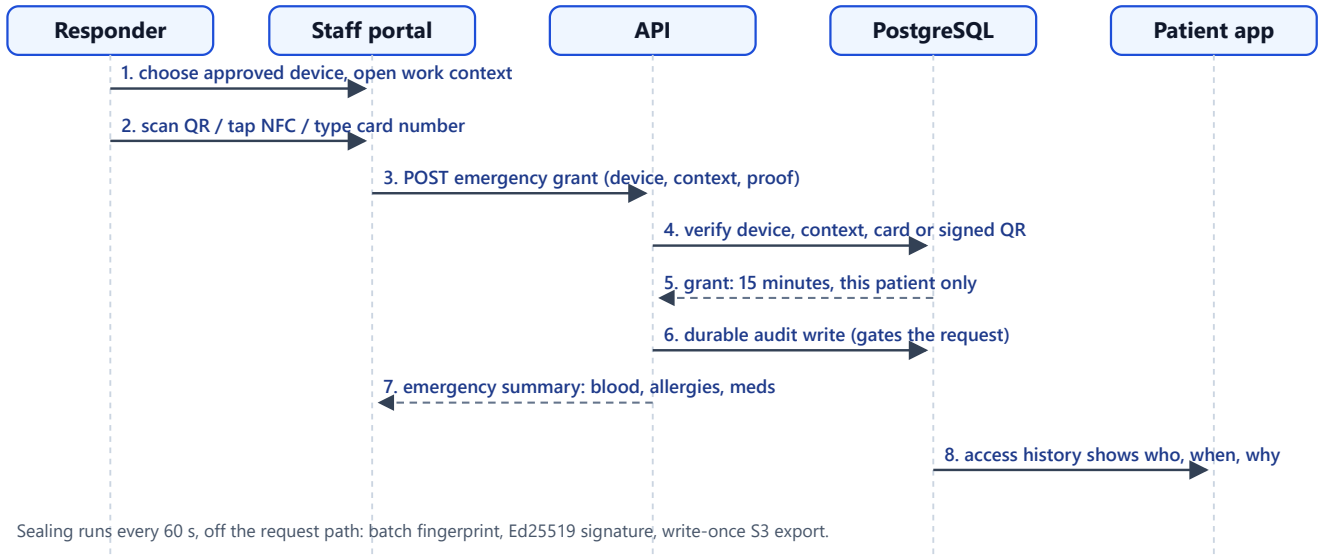


Figure 4. Emergency (break-glass) access. Only step 6, the durable audit row, may refuse a read; sealing never does.

6. The sealed audit stream

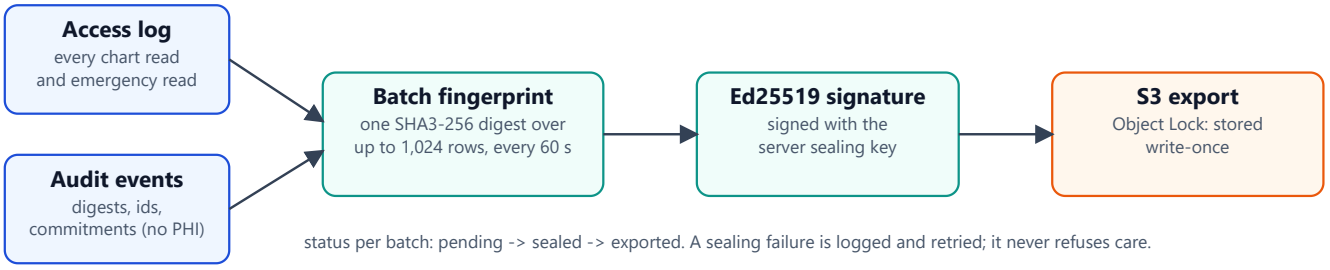


Figure 5. The sealed audit stream (ADR-0010): evidence of what happened, independent of the database host.

Only the durable database audit write may refuse a request; sealing and export run on a single-instance job behind an advisory lock and can fail without affecting care. Until checkpoints leave the database's host, they prove only what that host did not rewrite; on AWS they go to S3 Object Lock.

7. Real-time events

Notifications, messages and alerts are pushed over server-sent events, which work through proxies without a WebSocket upgrade. Each event has an audience: the **patient** only (their reminders), the **care team** (the patient and clinicians with an active grant, care relationship or emergency grant), **named accounts** (a message's recipients) or **administrators** (security alerts). An event never goes to everyone. Read and removed marks are stored per user, so a notification cleared on one device is cleared on all.

8. Data and clinical logic

- **Storage:** encrypted documents and queryable clinical data both live in PostgreSQL; there is no separate file store.
- **Clinical scoring is server-side:** qSOFA, SOFA, TIMI, START triage, Morse falls risk, Parkland burns fluids, Aldrete recovery, vital-sign bands and critical lab values are computed in one module and returned to the page, which only displays them. Thresholds a form needs come from a catalogue endpoint.
- **Unknown is not zero:** a score with missing inputs is returned as null with the number of criteria measured.
- **Patient visibility:** every endpoint that writes a record about a patient has a patient-scoped read.
- **Time:** reminders run on the clinic clock (Africa/Johannesburg).

9. Quality engineering

Layer	What runs	Result
Server tests	Unit and integration, against a live PostgreSQL	1,045 passing
Client tests	Vitest + Testing Library, both apps	855 staff, 280+ patient
Role journeys	Every role completes its own shift through the API with each page's real payload; a *different* user reads it back	276 steps
Browser tests	Playwright: emergency QR with a camera, live messaging on a phone, notifications, cross-role workflows	passing
Static gates in CI	35 checks, for example: no SQL concatenation, an endpoint inventory with authorisation, forms that send only what was entered, colour contrast, function size	0 failures

10. Operations

- **Backups:** pgBackRest with two repositories (local and S3), continuous WAL archiving, nightly backups at 01:47 UTC, and an automatic restore test.
- **Monitoring:** container logs go to CloudWatch; alarms on API errors, sign-in failures, account locks and host failure (with automatic recovery) e-mail the operator.
- **Cost:** one t3.small instance with S3, under a USD 60 per month budget alarm.

11. Known limits and next steps

- Phone-to-phone NFC needs a native Android app; the web supports reading NFC cards on Android Chrome only.
- One instance: fine for a pilot, while multi-instance scaling needs the sealing job's lock (already in place) and a managed database.
- Real patient data waits on POPIA authorisation and legal sign-off.

Measurements taken 20 October 2026 to 23 October 2026.

From a working product to a paying partner

MediChain is built and live. The business question is who pays first, what it costs to serve them, and what could go wrong.

Customers, in order

Segment	Why they buy	First offer
Private EMS operators	Responders need allergies and medicines on scene; they handle few records, so they are quick to adopt	Emergency summary and handover, per vehicle or per crew
Private clinics and GP groups	One shared record across their sites; patients who can see their own care	Staff portal and patient app, per facility
Hospital groups	Emergency department intake and handover; accountability for access	Integration pilot in one emergency department
Public facilities	National policy goals; after POPIA authorisation and procurement	Through partners and programmes

Revenue model

- **Subscription per facility or vehicle**, priced by active staff, with onboarding and support. Free for patients, always.
- **Implementation fees** for integration with an existing hospital system (FHIR endpoints already exist).
- Prices are hypotheses to set with the first partner; we will not publish numbers we have not tested.

Cost to serve

Item	Today	At pilot scale
Hosting (AWS Cape Town)	One t3.small instance, S3; budget alarm at USD 60 a month	A larger instance and a managed database; cost grows with facilities, not with patients
Distribution	Web apps: no app-store fees or review delays	The same, plus an Android app for NFC card emulation
Support	Founder	A clinical lead and a support engineer

Competitive position

Alternative	Strength	MediChain's angle
Paper folders	Familiar; no infrastructure	Available at the point of care; every access recorded
Hospital record systems (OpenMRS, Bahmni)	Mature clinical operations	Patient-held emergency summary and patient-visible access; can sit beside them
Emergency apps (iER)	Panic alerts, self-reported details	Clinician-maintained data, approved devices, reads shown to the patient

Referral platforms (Vula)	Clinician-to-specialist referrals	Complementary: the patient's own record and emergency access

Comparisons describe focus, not shortcomings.

Go-to-market

Phase	Milestone
1. Pilot (3 months)	One EMS or clinic partner; synthetic training, then an approved pilot of the emergency summary and handover
2. Proof (6 months)	Published pilot measures: seconds to critical information, handover completeness, patient understanding
3. Expansion	Paying facilities in Gauteng and the Western Cape; an Android app; integrations

Risks and how we handle them

Risk	Response
Regulatory approval takes time	Start with fictional and consented pilot data; Information Officer and POPIA prior authorisation are tracked as release gates
Clinicians will not adopt another system	Begin where the pain is sharpest (the emergency summary), keep each workflow to a few screens, measure adoption per shift
Patients lose phones or cards	A card number works by hand; the record is on the server, not the device
Single founder	First hires are a clinical lead and a second engineer; the code, tests and runbooks are written so others can take over
Connectivity and load-shedding	An offline QR summary; light web apps

Team and funding

Keorapetswe Kgoatlha, founder and developer, designed and built MediChain end to end (2nd place, Rust Africa Hackathon 2026). Company: Lukau Invasion (Pty) Ltd, 2026/600804/07. Funding sought from grants (for example NYDA and youth-entrepreneurship funds) and pilot revenue, for the first two hires and the regulatory work.

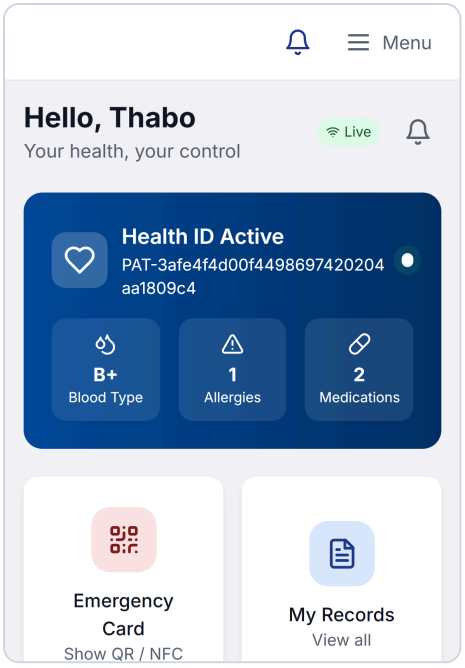
The ask

A pilot partner, and introductions to funders who back South African health technology.

A guided tour of the live product

Each screen below was captured on the live site with the fictional reviewer accounts, and comes with what it shows and why it matters.

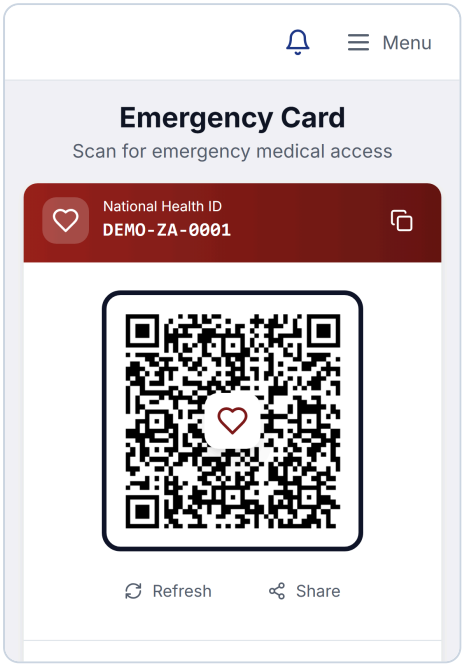
The patient's phone



Dashboard

Dashboard

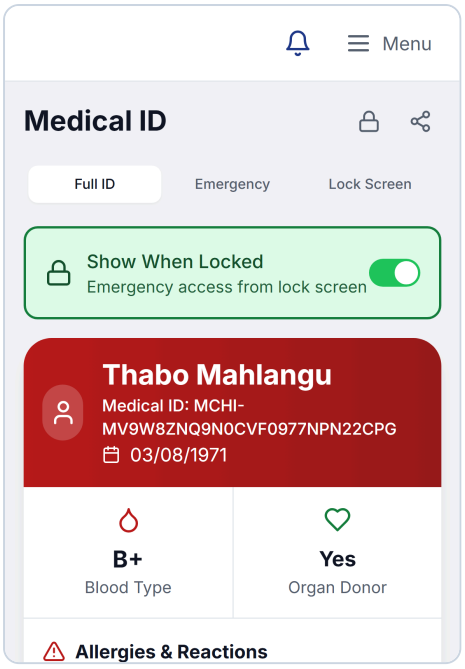
Thabo's health ID, blood type, allergy count and medicines at a glance, with shortcuts to his emergency card, records, access control and profile. A critical allergy is shown in red at the foot of the screen.



Emergency card

Emergency card

The QR a responder scans and the card number they can type instead. NFC status shows whether this phone can be tapped.

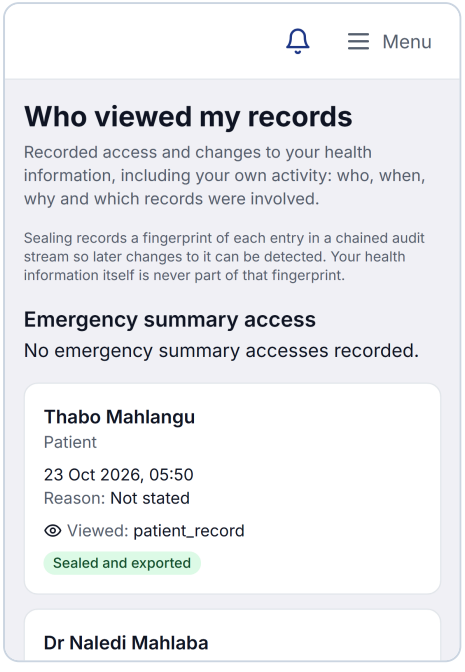


Medical ID

Medical ID

What a responder sees, and what Thabo can show from his lock screen: blood type, organ-donor status, allergies, conditions and medicines.

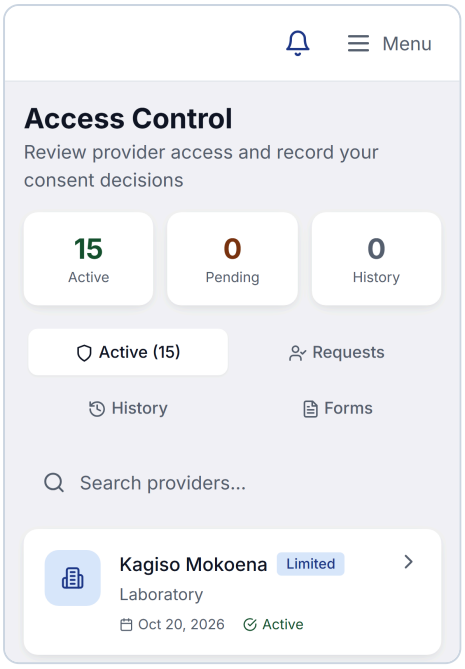
Control and transparency



Who viewed my records

Who viewed my records

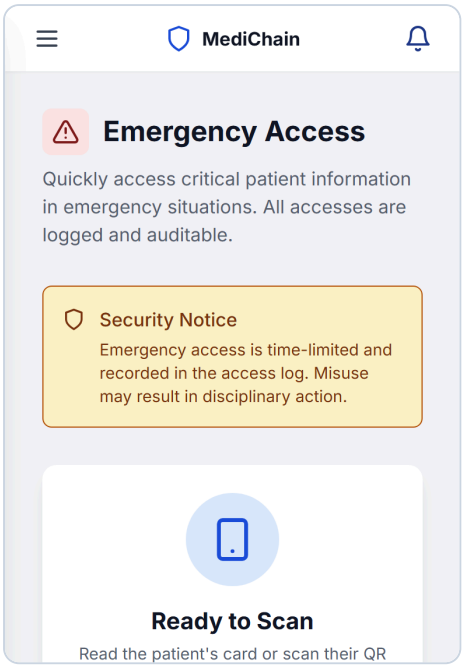
Every opening of Thabo's record: who, their role and department, when, why, and what they viewed. Each entry is marked as sealed and exported to the write-once audit store.



Access control

Access control

The clinicians who can open Thabo's record, each with an expiry. Thabo approves requests and withdraws access here.

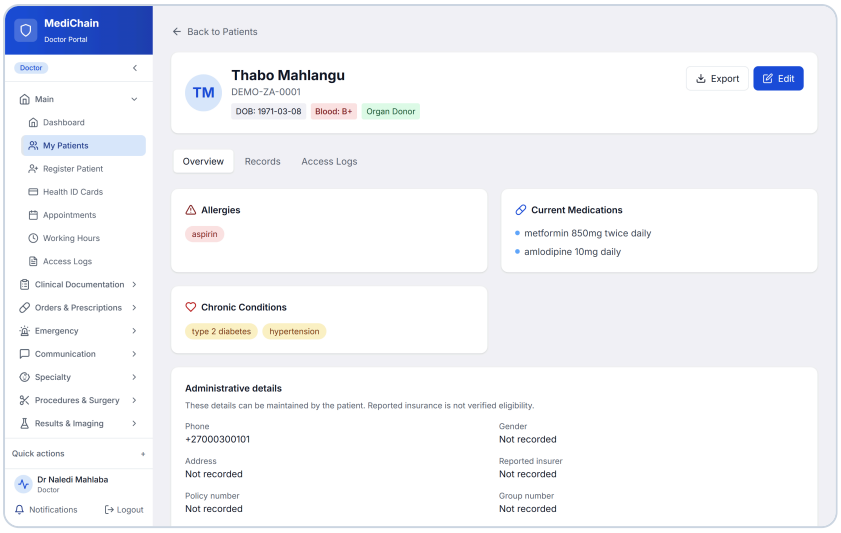


Emergency access on a responder's phone

Emergency access on a responder's phone

The staff portal on a phone: choose the approved device, then NFC card, QR code or the card number. Every access is time-limited and logged.

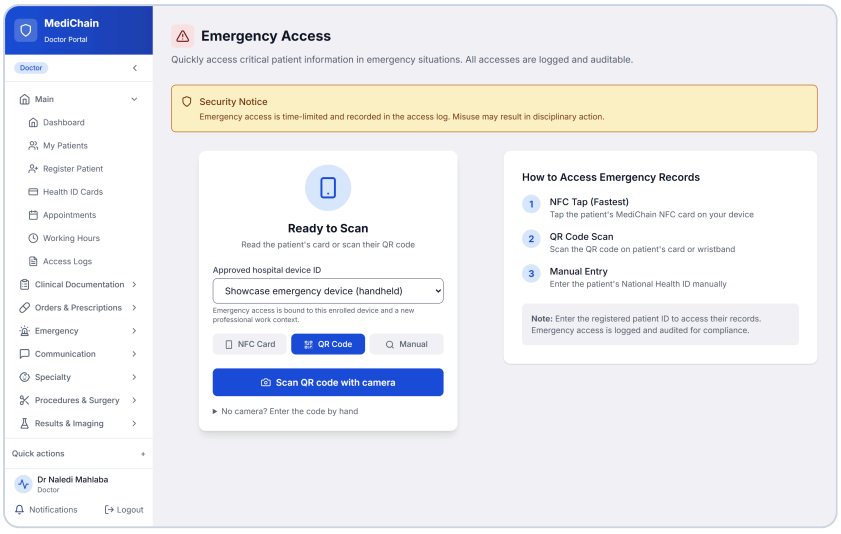
The staff portal



Patient chart

Patient chart

Dr Mahlaba's view of Thabo: allergies, current medications and chronic conditions first, then records and the access log. The tabs open his records and the access log for this chart.



Emergency access

Emergency access

The break-glass screen on a laptop: the approved device, the three ways to identify a patient, and a reminder that misuse is a disciplinary matter. The camera scanner opens from here.